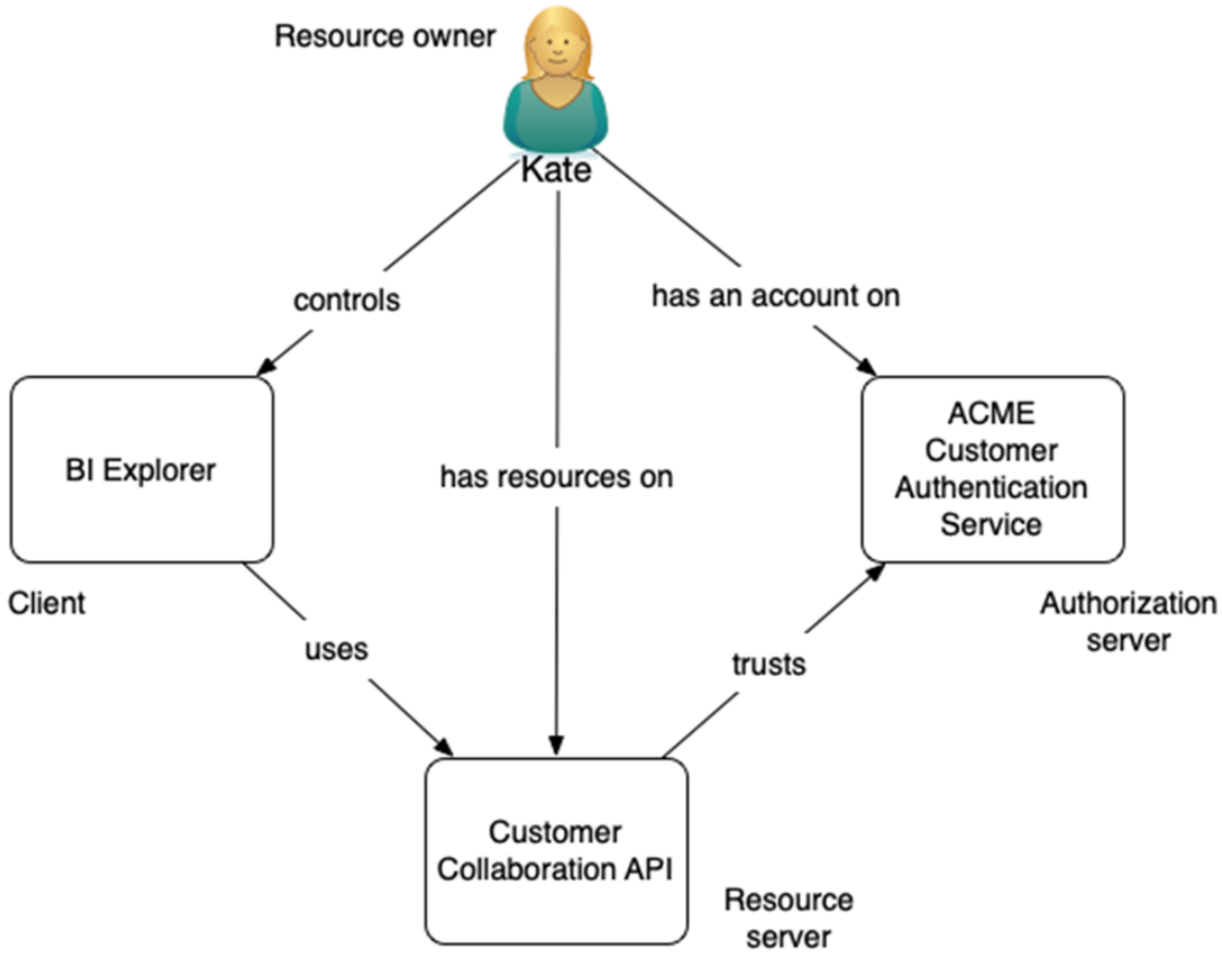


Figure 11.4 OAuth roles in action. Kate is the resource owner, BI Explorer is the client, ACME's Customer Authentication Service is the authorization server, and the Customer Collaboration API is the resource server.

In typical OAuth discussions, the authorization server is portrayed as making authorization decisions. However, in practice, especially at ACME, that's only partially true. The authorization server authenticates the user (or service), obtains consent, and issues a token with approved scopes. Scopes specify which API surfaces can be accessed. The actual, detailed authorization—whether this caller is permitted to perform a specific action on a particular resource—takes place later, at the resource server, where Cedar policies are evaluated for each API request.

This distinction is critical:

- OAuth tokens and scopes control the outer perimeter of what an API call may attempt.